Risk Management for Software

Faculty of Computer Science and Engineering, GIK

Handling Risk

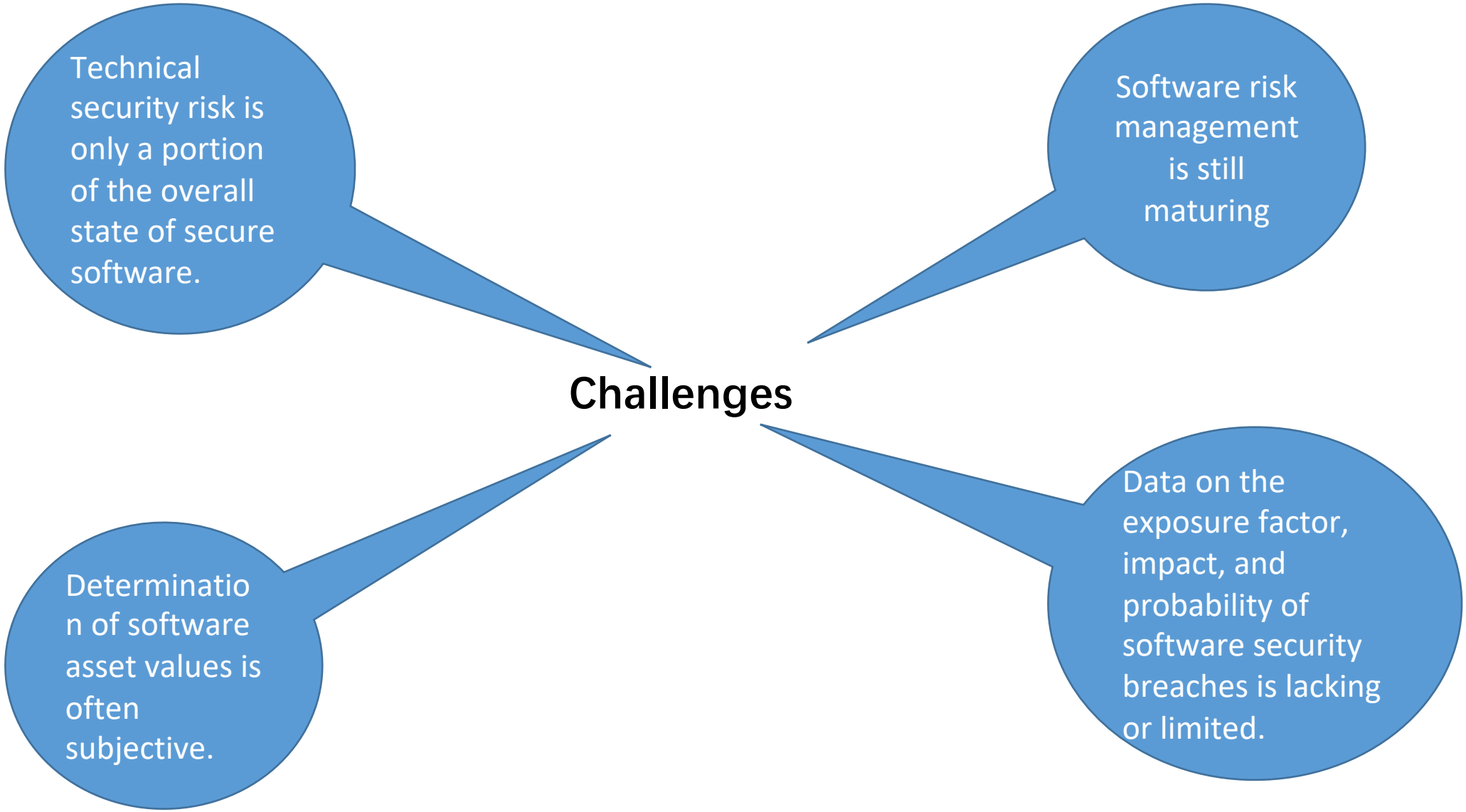
- Owners value assets **(software)** and wish to minimize risk to assets

All software has risks

Without risk management, small issues become disasters

Software risk management is not just about **security,** its about **reliability, trust, and business success**




Technical security risk is only a portion of the overall state of secure software.
Software risk management is still maturing
Challenges
Determinatio n of software asset values is often subjective.
Data on the exposure factor, impact, and probability of software security breaches is lacking or limited.

Handling Risk



The risk is left unhandled

This is highly ill-advised



What If?

The organization can find itself at the end of a class action law suit and regulatory oversight for not protecting the data that its customers have entrusted to it

Discontinue the service/product

Replaced by a newer product

What If?



Risk may be avoided but it must never be ignored.



What If?

To implement security controls (safeguards and countermeasures) to reduce the risk



Choose to this accept the risk that remains and continue business operations

Or they can choose to continue to mitigate it

What If?

The liability that is transferred and not necessarily the risk itself

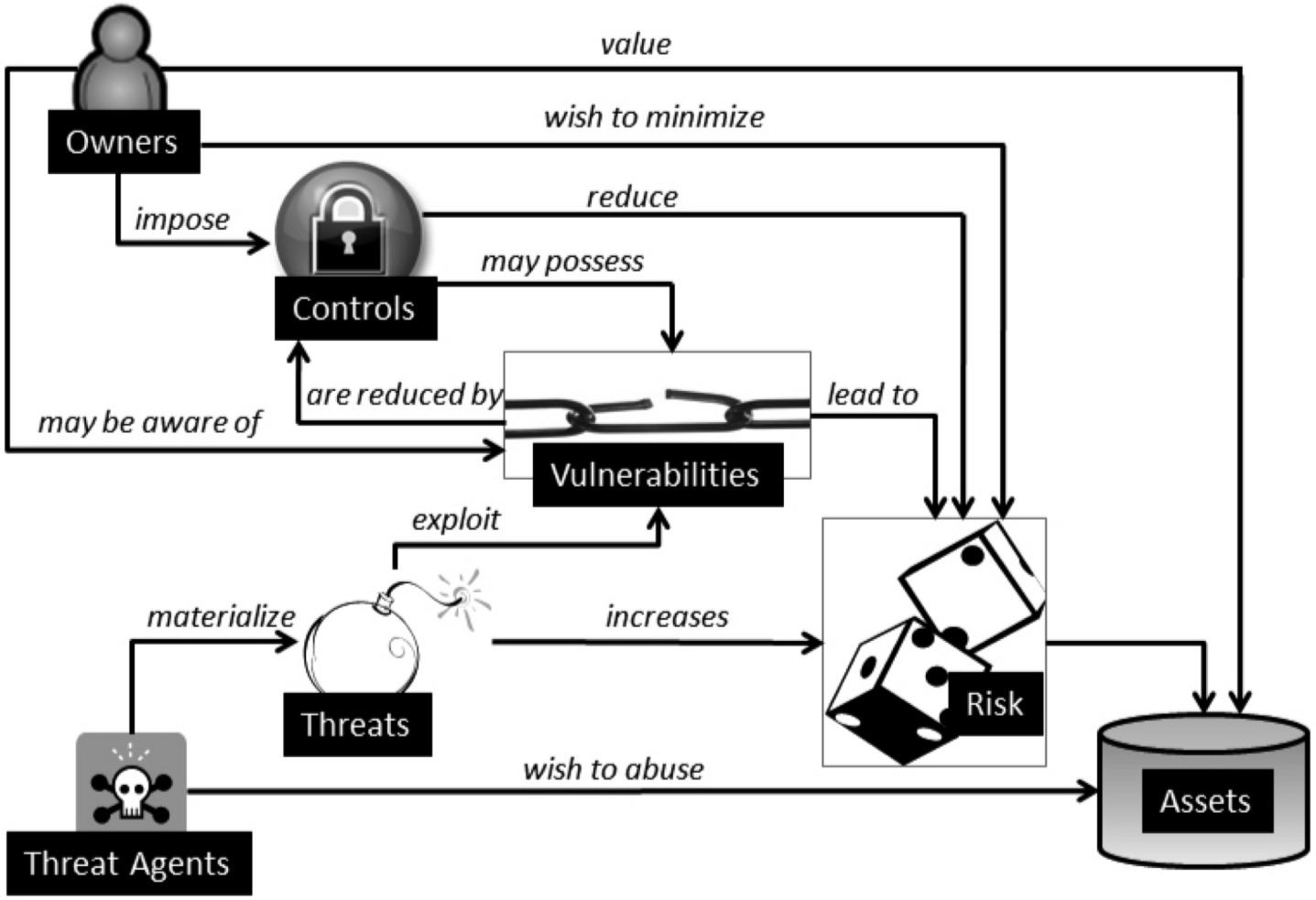
By buying insurance and using disclaimers

What If?

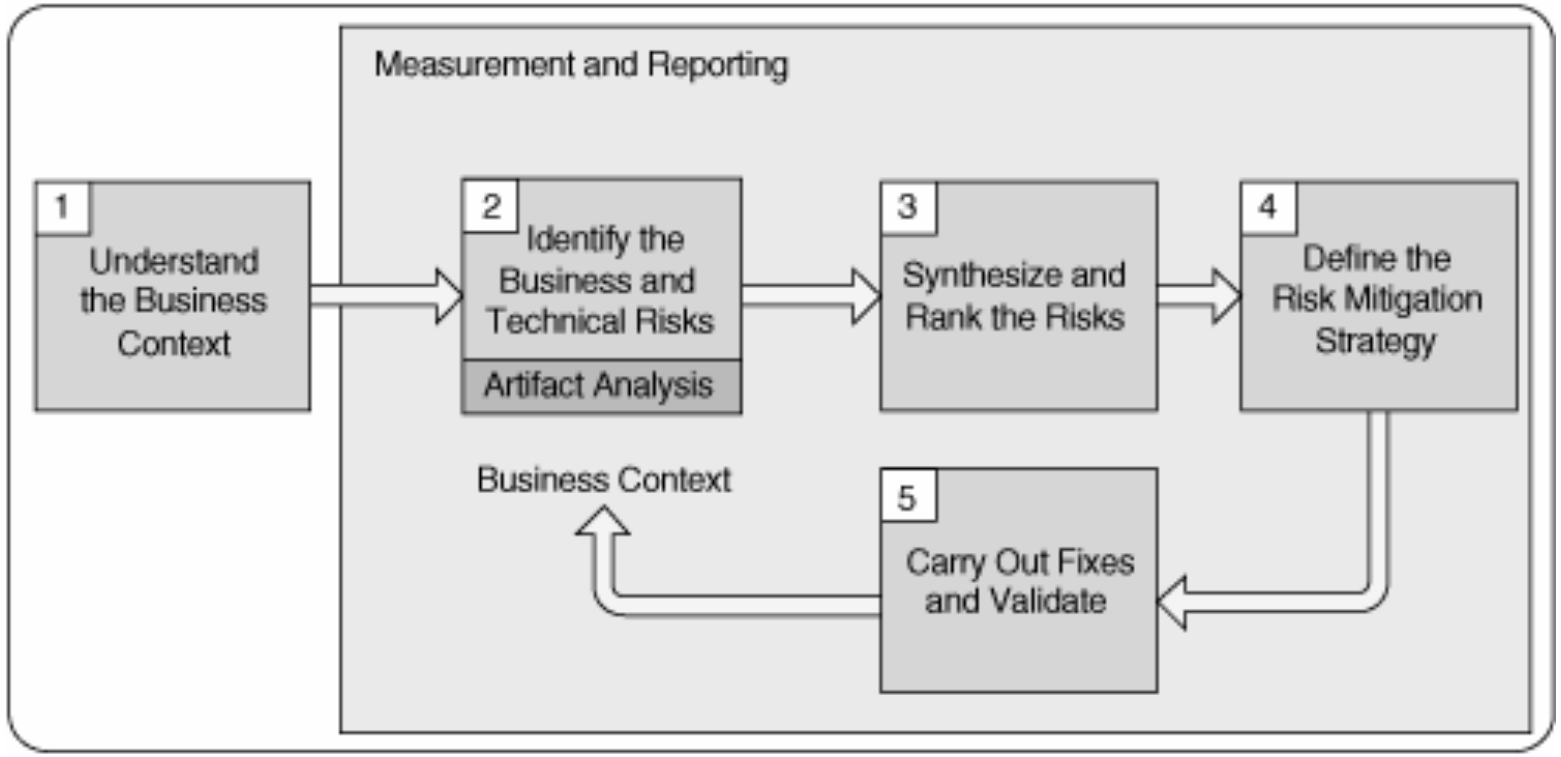


Transfer the risk to the end user. AS-IS

Risk Management – A View

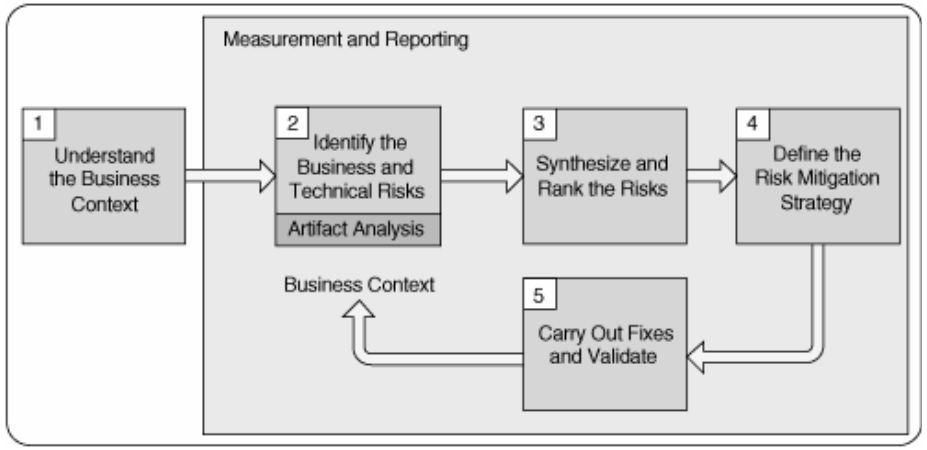


Risk Management - Five Stages



Risk Management - Five Stages

Understand the Business Context

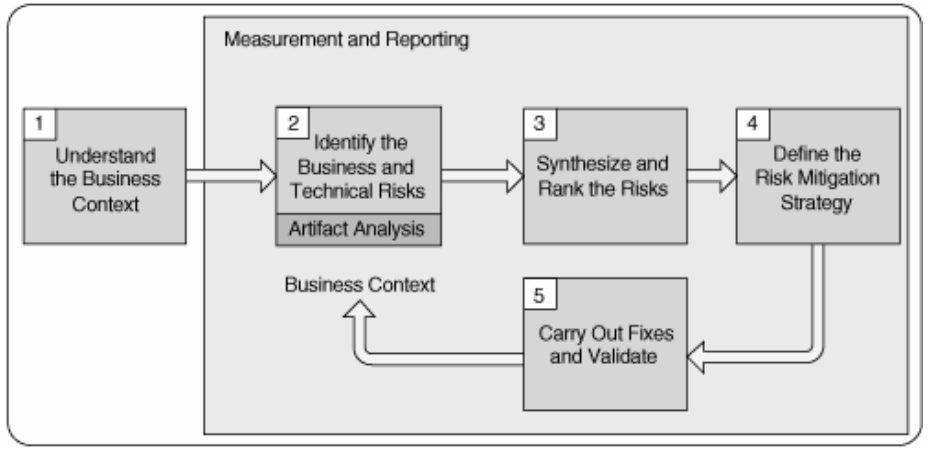


The purpose of this stage is to gather data to answer the all-important **"Who cares?"** question.

Extract and describe business goals, priorities, and circumstances in order to understand what kinds of software risks to care about and which business goals are paramount

Risk Management - Five Stages

Identify the Business and Technical Risks

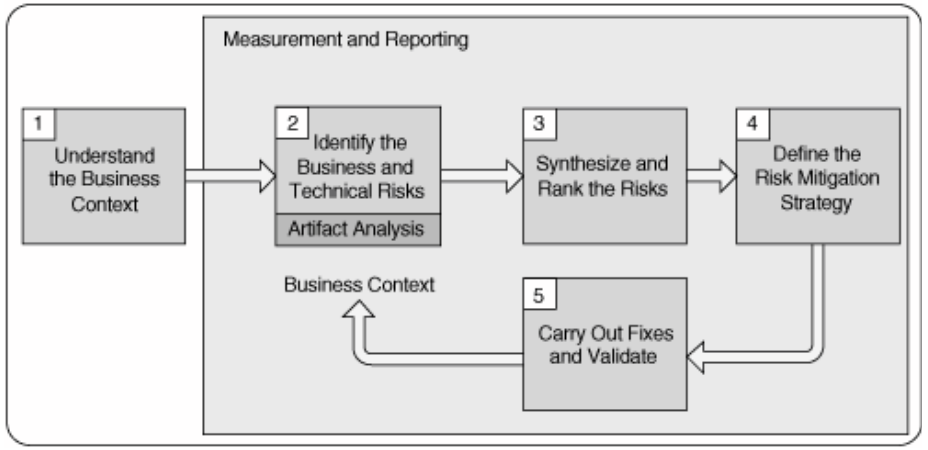


The ability to discover and describe technical risks and map them (through business risks) to business goals

The key to making risk management work for any business lies in tying technical risks to the business context in a meaningful way

Risk Management - Five Stages

Synthesize and Rank the Risks



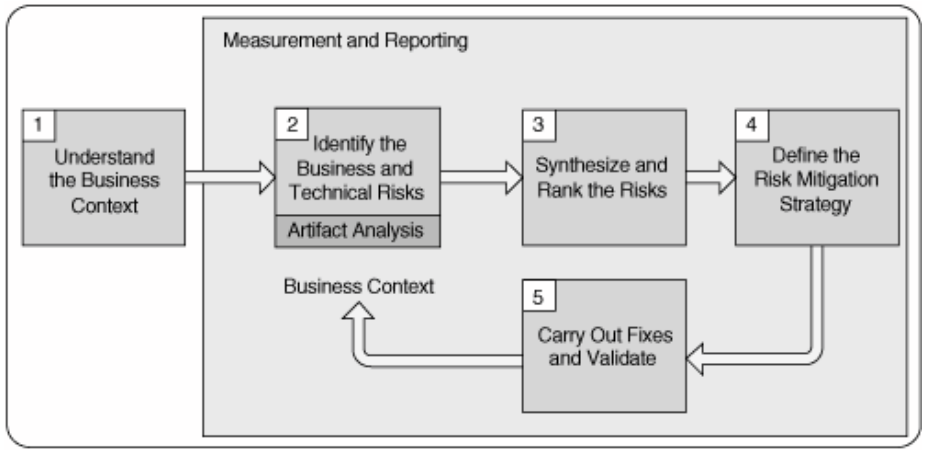
Answering the **"Who Cares?"** question

"What shall we do first given the **current risk situation**?"

"What is the best allocation of resources, especially in terms of risk mitigation activities?"

Risk Management - Five Stages

Define the Risk Mitigation Strategy



The inability to determine how to fix the problem holds true for a majority of security consultants.

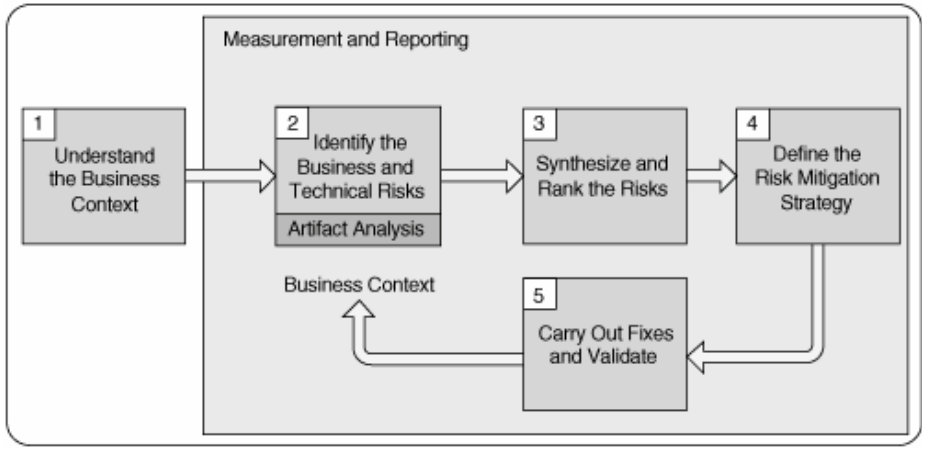
It is always easier to break something than to do design something that cant be broken.

See Dan Geer Foreword)

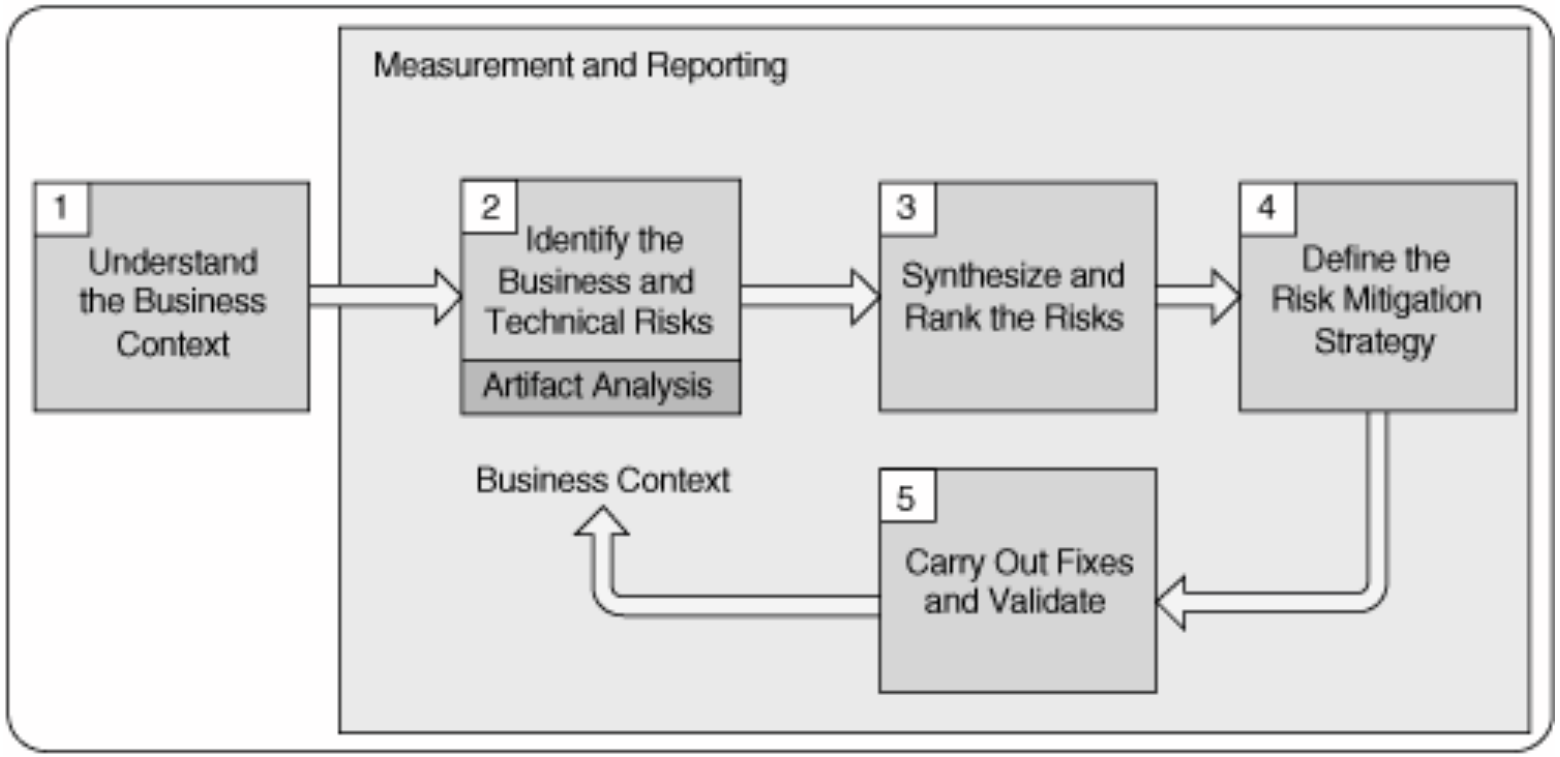
Nobody wants to hear about their problems without hearing some suggested fixes. A risk analysis is only as good as the mitigation strategy it contains

Risk Management - Five Stages

Carry Out Fixes and Validate



Risk mitigation is carried out according to the strategy defined in stage 4


Measurement and Reporting
1
Understand the Business Context
2
Identify the Business and Technical Risks
Artifact Analysis
3
Synthesize and Rank the Risks
4
Define the Risk Mitigation Strategy
Business Context
5
Carry Out Fixes and Validate

Risk Management

Understanding the Business Context

- *Gathering the Artifacts*
- *Conducting Project Research*

Identifying the Business and Technical Risks

- *Developing Risk Questionnaires*
- *Interviewing the Target Project Team*
- *Analyzing the Research and Interview Data*



KillerAppCo has launched **iWare 1.0**, a web-based software for managing user accounts, payments, and confidential business data. The iWare server runs on Linux, is accessible over the internet, and stores sensitive user information including emails, passwords, and payment details.

Rank	Business Goal	Description
H These goals are **critical** to the existence of the project	**TIME TO MARKET** iWare 1.0 Server must be released on January 1, 2008.	KillerAppCo desires to release iWare 1.0 on January 1, 2008, to achieve first-to-market status, which will enable KillerAppCo to secure 25% of the market prior to competitor entry.
M A failure to achieve a medium-rank business goal may result in a negative affect to high-rank goals	**AVAILABILITY** iWare 1.0 Server must provide 99.999% uptime.	A large share of the iWare 1.0 Server market consists of Fortune 500 companies with whom KillerAppCo will have SLAs. The server's availability is a critical factor in enabling KillerAppCo to meet the SLA requirements.
M	**ACCURACY** Transactions must be recorded with 100% accuracy, with no invalid, duplicate, or missing transactions.	Federal regulations stipulate that iWare 1.0 Server must perform all financial transactions with 100% accuracy.

Hint: **Low (L)** These goals affect only a small portion of the company's revenue. A small number of employees may be affected if these goals are not met.

Business Risk	Description
The software **fails** to meet the acceptance criteria required for release. **TIME TO MARKET**	The software may fail user acceptance testing criteria. Such failure will affect the release date, negatively affecting the time to market and possibly the company's brand and reputation. The share price of a publicly owned company may be negatively impacted.
System failures cause unplanned downtime. **AVAILABILITY**	Any **unplanned downtime** caused by system failures **negatively** affects the revenue from the project. In case of the existence of an SLA, this may cause direct monetary loss for the company. Unplanned downtime requires additional resources to execute disaster recovery plans and, possibly, to manually process the data usually processed by the system. News about the unplanned downtime may damage users' perceptions about the system and negatively affect users' demand for the system's services.

Business Risk	Description	Business Risk Indicators	Likelihood of Occurrence
The software **fails** to meet the acceptance criteria required for release. **TIME TO MARKET**	The software may fail user acceptance testing criteria. Such failure will affect the release date, negatively affecting the time to market and possibly the company's brand and reputation. The share price of a publicly owned company may be negatively impacted.	1. Number of missed project milestones 2. Number of critical-level errors	**H** The threat is highly motivated and sufficiently capable, and controls to prevent the risk from occurring are ineffective.
System failures cause unplanned downtime. **AVAILABILITY**	Any **unplanned downtime** caused by system failures **negatively** affects the revenue from the project. In case of the existence of an SLA, this may cause direct monetary loss for the company. Unplanned downtime requires additional resources to execute disaster recovery plans and, possibly, to manually process the data usually processed by the system. News about the unplanned downtime may damage users' perceptions about the system and negatively affect users' demand for the system's services.	1. Number of incorrect critical operations performed 2. Effort required to perform the same business functions using alternative routes	**M** The threat is motivated and capable, but controls are in place that may impede successful materialization of the risk.

Business Risk	Business Risk Indicators	Likelihood of Occurrence	Impact	Estimated Cost
The software **fails** to meet the acceptance criteria required for release. **TIME TO MARKET**	1. Number of missed project milestones 2. Number of critical-level errors	**H** The threat is highly motivated and sufficiently capable, and controls to prevent the risk from occurring are ineffective.	KillerAppCo will be unable to release the product to the market. **H**	**Revenue loss: $10 million Market share loss: 15% Brand and reputation damage: limited**
System failures cause unplanned downtime. **AVAILABILITY**	1. Number of incorrect critical operations performed 2. Effort required to perform the same business functions using alternative routes	**M** The threat is motivated and capable, but controls are in place that may impede successful materialization of the risk.	KillerAppCo will be unable to meet its clients' SLA availability requirements. **M**	Revenue loss: **$3 million** Market share loss: **5% Brand** and reputation damage: extreme

Business Impact Value	Definition
High (H)	(1) Very costly loss of major tangible assets or resources; (2) significant violation of, or harm or impediment to, an organization's mission, reputation, or interest; or (3) human death or serious injury.
Medium (M)	(1) Costly loss of tangible assets or resources; (2) violation of, or harm or impediment to, an organization's mission, reputation, or interest; or (3) human injury.
Low (L)	(1) Loss of some tangible assets or resources; or (2) a noticeable effect on an organization's mission, reputation, or interest.

Risk Severity

Likelihood \ Impact	L	M	H
H	L	M	H
M	L	M	M
L	L	L	L

H

Business Risk	Business Risk Indicators	Likelihood of Occurrence	Impact	Estimated Cost
The software **fails** to meet the acceptance criteria required for release. **TIME TO MARKET**	1. Number of missed project milestones 2. Number of critical-level errors	**H** The threat is highly motivated and sufficiently capable, and controls to prevent the risk from occurring are ineffective.	KillerAppCo will be unable to release the product to the market. **H**	**Revenue loss: $10 million Market share loss: 15% Brand and reputation damage: limited**
System failures cause unplanned downtime. **AVAILABILITY**	1. Number of incorrect critical operations performed 2. Effort required to perform the same business functions using alternative routes	**M** The threat is motivated and capable, but controls are in place that may impede successful materialization of the risk.	KillerAppCo will be unable to meet its clients' SLA availability requirements. **M**	Revenue loss: **$3 million** Market share loss: **5% Brand** and reputation damage: extreme

M

KillerAppCo's Technical Risks

ID	Technical Risk
TR1	Developers do not have access to quality assurance (QA) tools for unit testing.
TR2	QA tests do not fully evaluate requirements.
TR3	A. Testing does not cover fault tolerance. System failures are likely. B. Testing does not cover fault tolerance. Hardware failures can create incorrect transactions.
TR4	System is susceptible to denial-of-service attacks.
TR5	A. Poor random number generation (RNG) makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions.
TR6	Poor enforcement of access control rules allows misuse by insiders and outsiders.

Technical Risk Indicators

ID #	Technical Risk	Technical Risk Indicators	Likelihood

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	**H**

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	**H**
TR4	System is susceptible to **denial-of-service** attacks.		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	**H**
TR4	System is susceptible to **denial-of-service** attacks.	Number of unauthorized logins Mean server availability	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	**H**
TR4	System is susceptible to **denial-of-service** attacks.	Number of unauthorized logins Mean server availability	**H**

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	**H**
TR4	System is susceptible to **denial-of-service** attacks.	Number of unauthorized logins Mean server availability	**H**
TR5	A. Poor **RNG** makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor **RNG** makes crypto weak. Attackers can influence **transactions** or create illegitimate **transactions**.		

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	**H**
TR4	System is susceptible to **denial-of-service** attacks.	Number of unauthorized logins Mean server availability	**H**
TR5	A. Poor **RNG** makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor **RNG** makes crypto weak. Attackers can influence **transactions** or create illegitimate **transactions**.	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	**H**
TR4	System is susceptible to **denial-of-service** attacks.	Number of unauthorized logins Mean server availability	**H**
TR5	A. Poor **RNG** makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor **RNG** makes crypto weak. Attackers can influence **transactions** or create illegitimate **transactions**.	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	**H**

ID #	Technical Risk	Technical Risk Indicators	Likelihood
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	**H**
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	**H**
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	**H**
TR4	System is susceptible to **denial-of-service** attacks.	Number of unauthorized logins Mean server availability	**H**
TR5	A. Poor **RNG** makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor **RNG** makes crypto weak. Attackers can influence **transactions** or create illegitimate **transactions**.	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	**H**
TR6	Poor enforcement of **access control** rules allows misuse by insiders and outsiders.	Number of unauthorized accesses	**H**

ID #	Technical Risk	Technical Risk Indicators	Likelihood	Impact
TR1	Developers do not have access to **QA tools** for unit testing.	Number of development-phase bugs reported	H	The inaccessibility of QA tools for developers to use in unit testing may lead to QA problems and acceptance criteria failures.
TR2	QA tests do not fully evaluate **requirements**.	Number of requirements-phase bugs reported post-implementation	H	The partial evaluation of requirements by QA tests may lead to QA problems and acceptance criteria failures.
TR3	A. Testing does not cover **fault tolerance**. System failures are likely. B. Testing does not cover **fault tolerance**. Hardware failures can create incorrect **transactions**.	Number of faults reported Number of inaccurate transactions	H	Lack of fault tolerance test coverage may lead to unplanned downtime and inaccurate critical operations.
TR4	System is susceptible to **denial-of-service** attacks.	Number of unauthorized logins Mean server availability	H	DoS susceptibility may lead to unplanned downtime.
TR5	A. Poor **RNG** makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor **RNG** makes crypto weak. Attackers can influence **transactions** or create illegitimate **transactions**.	Number of unauthorized logins Number of unauthorized accesses Number of inaccurate transactions Number of IDS anomalies	H	Poor RNG implementation may lead to system failures, unexplained behavior, and inaccurate transactions.
TR6	Poor enforcement of **access control** rules allows misuse by insiders and outsiders.	Number of unauthorized accesses	H	Poor access rule enforcement may lead to unexplained behavior and system failures.

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.			

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.		

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.

Synthesizing and Ranking the Risks

Business Goal	Business Risk	ID #	Technical Risk
TIME TO MARKET iWare 1.0 Server must be released on January 1, 2008.	The software fails to meet the acceptance criteria required for release.	TR1	Developers do not have access to QA tools for unit testing.
		TR2	QA tests do not fully evaluate requirements.
AVAILABILITY iWare 1.0 Server must provide 99.999% uptime.	System failures cause unplanned downtime.	TR3	A. Testing does not cover fault tolerance. System failures are likely.
		TR4	System is susceptible to denial-of-service attacks.

Technical Risk Severity by Business Goal

ID	Technical Risk	Time to Market (H)	Availability (M)
TR1	Developers do not have access to QA tools for unit testing.	H	N/A
TR2	QA tests do not fully evaluate requirements.	H	N/A
TR3	A. Testing does not cover fault tolerance. System failures are likely. B. Testing does not cover fault tolerance. Hardware failures can create incorrect transactions.	N/A	H
TR4	System is susceptible to denial-of-service attacks.	N/A	H
TR5	A. Poor RNG makes crypto weak. Unauthorized access may cause system crashes or unexplained behavior. B. Poor RNG makes crypto weak. Attackers can influence transactions or create illegitimate transactions.	N/A	H
TR6	Poor enforcement of access control rules allows misuse by insiders and outsiders.	N/A	H

Reviewing the Risk Data

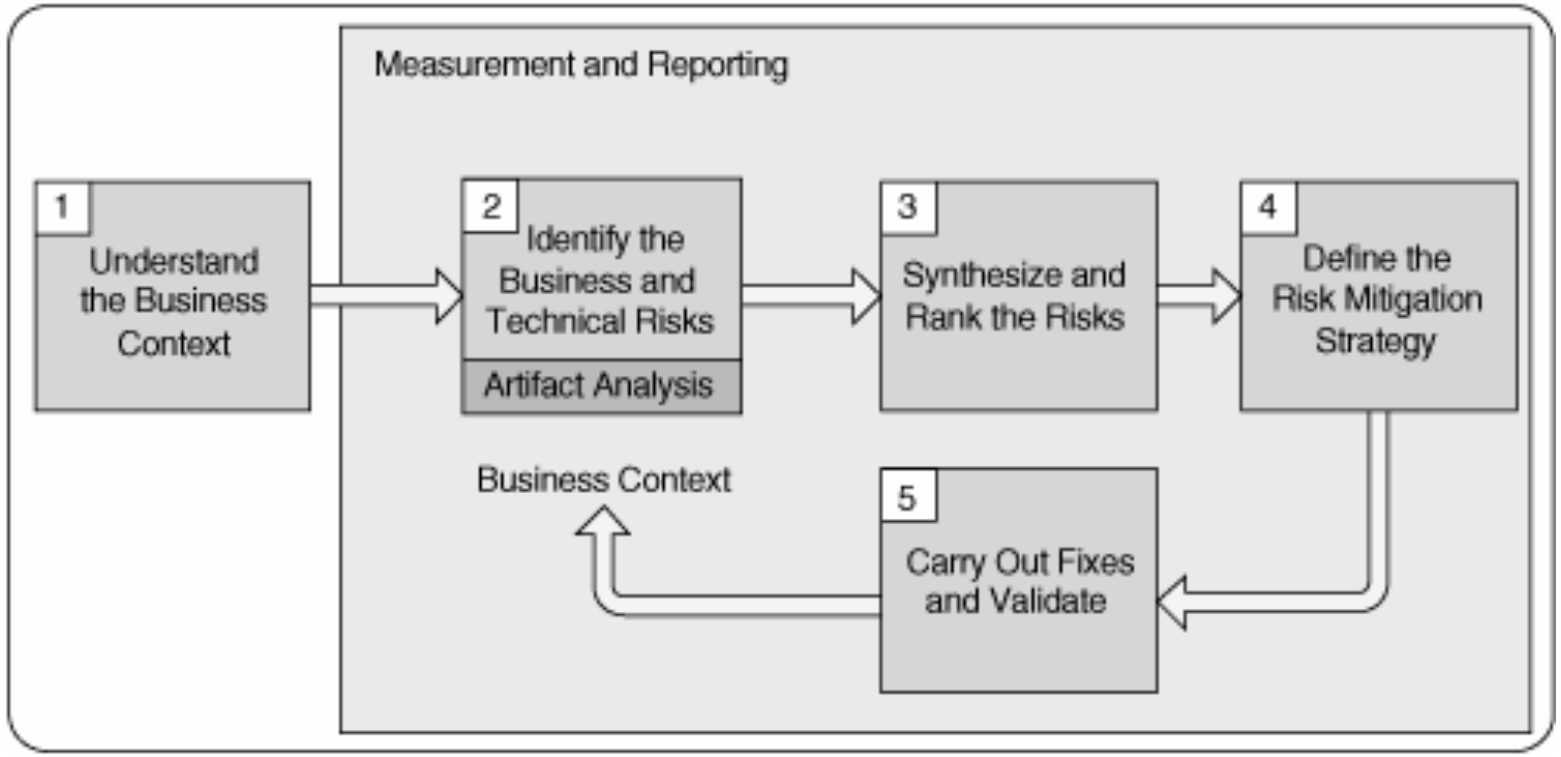
- Confirm the accuracy and comprehensiveness of the business and technical risks
- Confirm the risk likelihood, impact, and severity rankings
- Confirm the relationships between business goals, business risks, and technical risks
- Create a preliminary outline of the risk analysis report, which includes strategic risk mitigation content
- Conducting the Business and Technical Peer Review

Defining the Risk Mitigation Strategy

Business Risk	Supporting Technical Risk	Risk Mitigation Method: Improve QA in Early SDLC Phases	Add Fault Tolerance to QA Tests	Add Security Requirements and Security Requirements Testing to SDLC . . .
The software fails to meet the acceptance criteria required for release. **(H)**	TR1	H		
	TR2	H		M
System failures cause unplanned downtime. **(M)**	TR3	M	H	
	TR4		M	
Security weaknesses cause system failures. **(M)**	TR5			H
	TR6			H
	TR8			H
The software fails to perform critical operational functions correctly. **(M)**	TR3	M	H	
	TR5			H
	TR7			H

Carrying Out Fixes and Validating

- Execution of the risk mitigation strategy
- The validation plan is a test plan


Measurement and Reporting
1
Understand the Business Context
2
Identify the Business and Technical Risks
Artifact Analysis
3
Synthesize and Rank the Risks
4
Define the Risk Mitigation Strategy
Business Context
5
Carry Out Fixes and Validate

References

- Mano Paul - Official (ISC)2 Guide to the CSSLP CBK (2013, Auerbach Publications) - libgen.li

- Software-Security-Building-Security-In-by-Gary-McGraw-z-lib.org

Questions?